



PLANO DE GERENCIAMENTO DE RISCOS

Projeto TennisSync – Smart Tennis Arena

Data da criação: 17/08/2026

Integrantes: Stephany Aliyah Guimarães Eurípedes de Paula

Bernardo Seijas Cavalcante

Felipe Wakasa Klabunde

Carlos Roberto Santos Latorre

1. Introdução

O TennisSync é um projeto acadêmico desenvolvido para a Smart Tennis Arena, com a proposta de simular uma experiência de quadra de tênis por meio da integração de sensores, processamento de dados, interfaces de software e uma API responsável pela comunicação e leitura de informações corporais e/ou de movimento. Como o sistema depende de componentes conectados e de troca de dados, a segurança precisa ser considerada desde a arquitetura.

Este documento adapta a estrutura do Plano de Gerenciamento de Riscos fornecido como modelo e a aplica ao contexto do TennisSync. O foco desta entrega é identificar riscos e vulnerabilidades potenciais, classificá-los por probabilidade e impacto, definir respostas e estabelecer um processo de acompanhamento.

2. Objetivos

- Identificar riscos de segurança, rede, software, sensores, dados e infraestrutura do TennisSync.
- Avaliar probabilidade e impacto de cada risco por uma matriz 5×5 .
- Definir medidas preventivas, corretivas e de contingência.
- Estabelecer controles de segurança aplicáveis ao sistema e à API.
- Criar uma base para a futura validação do código-fonte por análise estática e testes.
- Registrar responsáveis e critérios para monitoramento dos riscos até a entrega.

3. Metodologia

A metodologia segue quatro etapas: identificação, análise, tratamento e acompanhamento. A identificação considera os ativos do sistema e seus possíveis vetores de ataque. A análise usa probabilidade e impacto em escala de 1 a 5. O tratamento define a resposta e os controles. O acompanhamento verifica se os controles foram implementados e se o nível de risco residual é aceitável.

Como referências técnicas, o trabalho utiliza o NIST Cybersecurity Framework 2.0, que organiza resultados de segurança nas funções Governar, Identificar, Proteger, Detectar, Responder e Recuperar, e o OWASP Top 10:2025 como referência para riscos de aplicações web.

4. Papéis e responsabilidades

Papel	Responsabilidades	Responsável
Gerente do projeto	Consolidar o plano, acompanhar riscos, cobrar ações e atualizar o status.	Bernardo Seijas Cavalcante
Desenvolvimento	Corrigir vulnerabilidades no código, validar entradas, autenticação e dependências.	Equipe TennisSync
Redes/Cibersegurança	Avaliar comunicação, TLS, portas, autenticação, exposição e testes de segurança.	Equipe TennisSync
Sensores/IoT	Validar integridade das leituras, firmware e comunicação dos dispositivos.	Equipe TennisSync
Dados/Infraestrutura	Proteger armazenamento, backups, disponibilidade, logs e configuração.	Equipe TennisSync

5. Organização e cronograma para gerenciamento de riscos

O gerenciamento deve ocorrer de forma contínua até a entrega, com revisão a cada alteração relevante na arquitetura ou no código.

Período	Atividade	Responsável	Entregável
17–22/08	Inventário de ativos, componentes do código e arquitetura do TennisSync, identificando aplicação, API, sensors, banco/armazenamento, bibliotecas, serviços e pontos de comunicação	Equipe	Mapa do Sistema, arquitetura e inventário de ativos.
23–29/08	Identificação e classificação dos riscos técnicos, analisando API, autenticação, entradas de dados, comunicação com sensores, armazenamento, dependências e infraestrutura.	Equipe	Matriz preliminar de riscos.
30/08–05/09	Implementação dos primeiros controles de segurança no código e na infraestrutura, incluindo validação de entradas, autenticação/autorização, proteção do API, configuração segura e proteção das comunicações.	Desenvolvimento/Redes	Controles de segurança aplicados
06-12/09	Testes de segurança da aplicação e revisão das vulnerabilidades, verificando endpoints da API, permissões, entradas manipuladas, tratamento de erros, dependências e comunicação entre componentes.	Equipe	Evidências nos testes e correções
13-19/09	Revisão técnica do relatório e consolidação das evidências, relacionando os riscos encontrados às medidas de segurança implementadas no TennisSync.	Gerente/Equipe	Versão final do relatório
20-25/09	Entrega da primeira etapa do projeto, contendo documentação, relatório de riscos, relatório de vulnerabilidades e	Equipe	PDF/HTML + código-fonte

	Código-fonte disponível para avaliação		
26/09-02/10	Elaboração detalhada do plano de resposta aos riscos, definido para cada risco identificado a ação de tratamento, prioridade, responsável, prazo e controle a ser aplicado no sistema/Código.	Equipe	Plano de respostas aos riscos
03-09/10	Implementação das ações de resposta e dos controles de segurança definidos, realizando alterações no Código, API, autenticação, comunicação, tratamento de entradas, dependências e configurações.	Desenvolvimento/Redes	Controles e ações de mitigação aplicados
10-16/10	Testes e validação das respostas implementadas, verificando se as correções realmente reduzem as vulnerabilidades e se o sistema continua funcionando corretamente após as alterações.	Equipe	Evidências nos testes e validações
17-23/10	Reavaliação dos riscos após a aplicação dos controles, comparando os níveis de probabilidade e impacto anteriores com os riscos restantes e cálculo do risco residual	Gerente/Equipe	Matriz de riscos atualizada
24-30/10	Acompanhamento e monitoramento dos riscos residuais, observando logs, falhas, alterações no código, dependências, funcionamento da API e novos riscos decorrentes da evolução do projeto.	Equipe	Registro de acompanhamento e ocorrências
31/10-05/11	Consolidação e revisão final do gerenciamento de riscos, reunindo matriz inicial, respostas, controles aplicados, testes, riscos residuais e documentação final do	Gerente/Equipe	Relatório e documentação consolidados

	TennisSync		
--	------------	--	--

6. Categorias de riscos

Categoria	Abrangência
Tecnologia e software	API, código, bibliotecas, autenticação, configuração, tratamento de erros.
Rede e comunicação	Wi-Fi/Ethernet conforme arquitetura, TLS, exposição de portas e tráfego.
Dados e privacidade	Dados de movimento/corpo, identificadores, resultados e registros de uso.
Sensores e dispositivos	Integridade das leituras, firmware, spoofing, indisponibilidade e manipulação física.
Infraestrutura	Servidor, nuvem, banco, armazenamento, disponibilidade e backups.
Pessoas e operação	Credenciais, permissões, procedimentos, atualização, resposta a incidentes.

7. Definição da matriz de riscos

A probabilidade e o impacto são classificados de 1 a 5. O nível de risco é calculado por $P \times I$.

Impacto \ Prob.	1 Muito baixa	2 Baixa	3 Média	4 Alta	5 Muito alta
1 Muito baixo	1 – Baixo	2 – Baixo	3 – Baixo	4 – Baixo	5 – Médio
2 Baixo	2 – Baixo	4 – Baixo	6 – Médio	8 – Médio	10 – Alto
3 Médio	3 – Baixo	6 – Médio	9 – Médio	12 – Alto	15 – Alto
4 Alto	4 – Baixo	8 – Médio	12 – Alto	16 – Alto	20 – Crítico
5 Muito alto	5 – Médio	10 – Alto	15 – Alto	20 – Crítico	25 – Crítico

Critério de tratamento: Baixo = acompanhar; Médio = planejar mitigação; Alto = tratar prioritariamente; Crítico = ação imediata e bloqueio da liberação até haver controle adequado.

8. Identificação e análise dos riscos

ID	Risco	Categoria	P	I	Nível	Resposta
R01	Acesso não autorizado à API	Cibersegurança / API	3	5	15 – Alto	Mitigar
R02	Interceptação de dados entre sensores, aplicação e API	Rede / Comunicação	3	5	15 – Alto	Mitigar
R03	Exposição de dados corporais ou dados de uso	Dados / Privacidade	3	5	15 – Alto	Mitigar
R04	Credenciais ou chaves da API armazenadas no código	Código / Configuração	3	5	15 – Alto	Mitigar
R05	Entrada de dados sem validação adequada	Aplicação / API	3	4	12 – Alto	Mitigar
R06	Injeção em consultas ou comandos	Código / API	2	5	10 – Alto	Mitigar
R07	Dependências/bibliotecas vulneráveis ou desatualizadas	Software / Supply Chain	3	4	12 – Alto	Mitigar
R08	Falhas de autenticação e	Identidade /	2	5	10 – Alto	Mitigar

	autorização	Acesso				
R09	Ausência ou insuficiência de logs e alertas	Monitoramento	3	3	9 – Médio	Mitigar
R10	Manipulação de dados enviados pelos sensores	Sensores / Integridade	3	4	12 – Alto	Mitigar
R11	Indisponibilidade da API ou serviço de processamento	Infraestrutura	2	5	10 – Alto	Mitigar/Contingência
R12	Tratamento inadequado de erros e exceções	Código	3	3	9 – Médio	Mitigar
R13	Configuração insegura do servidor ou ambiente	Infraestrutura / Configuração	2	5	10 – Alto	Mitigar
R14	Perda ou corrupção de dados	Dados / Continuidade	2	4	8 – Médio	Mitigar/Contingência

9. Segurança aplicada ao TennisSync

- Autenticação: exigir credenciais/tokens válidos para operações protegidas.
- Autorização: separar permissões por função e aplicar o princípio do menor privilégio.
- Criptografia: utilizar TLS na comunicação e criptografia adequada para dados armazenados quando necessário.
- Gestão de segredos: nunca armazenar senhas, tokens ou chaves diretamente no código-fonte.
- Validação de entradas: validar dados provenientes da API, sensores, interface e integrações externas.
- Proteção da API: limitar requisições, controlar origem quando aplicável e impedir exposição desnecessária de endpoints.
- Dependências: manter bibliotecas atualizadas e realizar verificação automatizada de vulnerabilidades.
- Logs e monitoramento: registrar eventos relevantes sem armazenar segredos ou dados desnecessários.
- Backups e recuperação: manter cópias e testar restauração para dados/configurações importantes.
- Hardening: desabilitar serviços não utilizados, revisar portas, permissões e configurações antes da demonstração.

10. Acompanhamento e monitoramento

- Revisar a matriz após qualquer mudança de arquitetura, API, sensores ou armazenamento.
- Registrar cada risco com status: Aberto, Em tratamento, Mitigado ou Aceito.
- Reexecutar testes após cada correção de segurança relevante.
- Monitorar dependências e corrigir vulnerabilidades conhecidas antes da entrega.
- Revisar permissões, credenciais, endpoints e configurações de produção/demonstração.
- Guardar evidências: prints de testes, resultados de ferramentas, commits de correção e configurações relevantes.
- Após a mitigação, calcular novamente o risco residual e documentar a justificativa.

11. Critérios de aceitação de segurança

- Nenhum risco crítico sem plano de tratamento aprovado.
- Endpoints protegidos não devem responder a operações sensíveis sem autenticação/autorização.
- Segredos não devem permanecer no código-fonte ou em arquivos públicos do repositório.
- Comunicação sensível deve utilizar TLS.

- Entradas externas devem ser validadas antes do processamento.
- Dependências devem ser verificadas antes da entrega.
- Logs de segurança mínimos devem estar habilitados sem registrar credenciais ou segredos.
- Deve existir procedimento de recuperação para dados/configurações relevantes.

12. Conclusão

O gerenciamento de riscos do TennisSync deve tratar segurança como parte da arquitetura e não apenas como uma etapa final. Os principais pontos de atenção concentram-se na API, comunicação entre dispositivos, proteção dos dados, credenciais, validação das entradas, dependências, configuração e monitoramento. A matriz apresentada permite priorizar os controles e o plano de resposta estabelece ações práticas para reduzir a exposição.

Este documento constitui a versão-base da primeira entrega. A etapa seguinte recomendada é confrontar cada item com o código-fonte real e anexar evidências dos testes realizados, substituindo riscos potenciais por vulnerabilidades confirmadas quando houver evidência técnica.

13. Aprovação:

Nome	Cargo	Assinatura	Data
Bernardo Seijas Cavalcante	Gerente do Projeto		17/08/2026
Smart Tennis Arena	Patrocinador do Projeto		17/08/2026

14. Referências

- OWASP Foundation. OWASP Top 10:2025 – versão em português. <https://top10.owasp.org/2025/pt-BR/>
- NIST. The NIST Cybersecurity Framework (CSF) 2.0. NIST CSWP 29, 2024. <https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20>
- NIST. NIST Cybersecurity Framework 2.0: Resource & Overview Guide. NIST SP 1299, 2024. <https://www.nist.gov/publications/nist-cybersecurity-framework-20-resource-overview-guide>
- NIST. Guide for Conducting Risk Assessments. NIST SP 800-30 Rev. 1, 2012. <https://www.nist.gov/publications/guide-conducting-risk-assessments>